

Entity X Cybersecurity Policy Pack

Synthetic test document for Noryx compliance assessment.

Document Classification: Internal Training Data

Version: 1.0 | Date: 2026-05-06

This document is intentionally mixed: some requirements are well covered, some are partially covered, and some are missing. It is designed to test policy ingestion, evidence extraction, compliance scoring, and gap analysis.

Framework	Expected Sample Score
NCA ECC 2024	68.75%
NIST CSF 2.0	75.00%
SAMA CSF 1.0	66.67%
ISO 27001 reference	70.83%

Policy Sections

1. Information Security Policy

Entity X maintains an Information Security Management Program approved by the Executive Committee. The program applies to all employees, contractors, systems, cloud services, and third-party connections that process Entity X information.

The Chief Information Security Officer (CISO) owns this policy pack and reports cybersecurity status to the Executive Committee every quarter.

All cybersecurity policies are reviewed at least annually or after material changes in regulation, technology, business operations, or threat landscape.

Entity X maintains a policy exception register. Exceptions require business-owner justification, CISO approval, compensating controls, and an expiry date not exceeding twelve months.

2. Cybersecurity Governance Policy

Entity X has an approved cybersecurity strategy for 2026-2028. The strategy defines initiatives for identity hardening, vulnerability reduction, cloud security, security awareness, and incident response maturity.

Cybersecurity roles and responsibilities are documented for the Board Sponsor, CISO, IT Operations Manager, System Owners, Data Owners, and Employees.

A Cybersecurity Steering Committee meets quarterly to review risk posture, project progress, incidents, and compliance obligations.

The current governance policy does not define a formal enterprise cyber risk appetite statement approved by the Board.

3. Asset Management Policy

Entity X maintains an inventory of laptops, servers, network devices, cloud workloads, business applications, and SaaS services. Each asset has an owner, location, criticality rating, and lifecycle status.

The asset inventory is reconciled monthly using endpoint management, cloud account exports, and procurement records.

Critical systems are assigned system owners who approve access, maintenance windows, and recovery requirements.

Entity X has not completed a formal data classification register for all information assets. Classification is currently limited to customer records and finance data.

4. Access Control and Password Policy

All users must have unique user IDs. Shared user accounts are prohibited except for documented break-glass accounts approved by the CISO.

Administrative access, VPN access, cloud console access, and remote access require multi-factor authentication.

New access requests require manager approval and system-owner approval before provisioning.

User access reviews are performed quarterly for critical systems and semi-annually for non-critical systems.

Passwords must be at least 12 characters, block common passwords, and be changed immediately after suspected compromise. Password history prevents reuse of the last 10 passwords.

Entity X has not fully implemented automated joiner-mover-leaver workflows. Some access removals are processed manually through service desk tickets.

5. Cryptography Policy

Sensitive data in transit must use TLS 1.2 or higher. Sensitive data at rest must use AES-256 or an equivalent approved encryption mechanism.

Encryption keys for production systems must be stored in a managed key vault or hardware security module where supported.

Key rotation is required annually for application secrets and immediately after suspected exposure.

The cryptography standard does not identify Saudi national cryptographic requirements or a locally approved algorithm catalogue.

6. Backup and Recovery Policy

Critical systems are backed up daily. Important business systems are backed up at least weekly.

Backups are encrypted, access-controlled, and stored in a separate backup repository from the production environment.

Restore tests are performed monthly for critical systems and quarterly for non-critical systems. Test results are documented and reviewed by IT Operations.

Recovery Time Objective (RTO) and Recovery Point Objective (RPO) values are documented for critical systems.

7. Incident Response Policy

Entity X maintains an incident response plan with severity levels, escalation contacts, communication channels, and decision authority.

Security incidents must be reported to the CISO within 24 hours of discovery. High-severity incidents must be escalated to the Executive Committee.

The incident response team conducts one tabletop exercise per year and records lessons learned.

The policy does not define a formal digital forensics evidence-handling procedure or external forensic retainer.

8. Vulnerability and Patch Management Policy

Authenticated vulnerability scans are performed monthly on servers and quarterly on network devices.

Critical vulnerabilities on internet-facing systems must be remediated within 15 calendar days. High vulnerabilities must be remediated within 30 calendar days.

Patch exceptions require risk acceptance by the system owner and compensating controls approved by the CISO.

Entity X has not performed an independent penetration test during the last twelve months.

9. Third-Party and Cloud Security Policy

Third-party contracts for technology services include confidentiality, security incident notification, access control, and right-to-audit clauses.

Cloud services must be approved by the CISO and IT Operations before production use.

Vendors handling sensitive data complete a security questionnaire before onboarding.

Entity X does not yet perform periodic security reassessments for all active vendors after onboarding.

10. Awareness and Training Policy

All employees complete cybersecurity awareness training during onboarding and annually thereafter.

Privileged users receive additional secure administration training at least annually.

Entity X runs phishing simulations twice per year and reports results to the Cybersecurity Steering Committee.

Employees must acknowledge acceptable use, password, and incident reporting requirements annually.

11. Logging and Monitoring Policy

Security logs from firewalls, servers, identity providers, endpoint protection, and critical applications are forwarded to a centralized logging platform.

Alerts are configured for privileged account changes, malware detections, repeated failed logins, suspicious VPN activity, and disabled security tools.

Critical security logs are retained online for 90 days and archived for 180 days.

The current logging policy does not require one-year retention for all critical cybersecurity event logs.

12. Physical and Environmental Security Policy

Data center and network rooms require badge access and visitor escort. Access is reviewed quarterly by Facilities and IT Operations.

CCTV is deployed at building entrances and server-room doors. Recordings are retained for 30 days.

Portable media containing sensitive information must be encrypted and approved by the CISO.

Known Intended Gaps

- No formal Board-approved cyber risk appetite statement.
- No complete data classification register across all information assets.
- No Saudi/local cryptographic algorithm catalogue.
- No independent penetration test during the last twelve months.
- No one-year retention requirement for all critical cybersecurity event logs.
- No complete periodic reassessment process for all active third-party vendors.
- No detailed secure email service policy.
- No formal digital forensics evidence-handling procedure.